

CS-03 Metrics & Remediation Plan

Prepared by Ismail Victor Elias

1. Metrics Plan

The kit uses measurable indicators to evaluate awareness training. Suggested metrics are training completion rate, average quiz score, percentage scoring at least 80%, most-missed topic and correct reporting behavior during an authorized safe exercise.

2. Suggested Metrics

Completion rate: $\text{completed participants} \div \text{assigned participants} \times 100$. Target: $\geq 90\%$.

Average quiz score: mean percentage across completed quizzes. Target: $\geq 80\%$.

80%+ pass rate: $\text{participants scoring } \geq 80\% \div \text{completed quizzes} \times 100$. Target: $\geq 80\%$.

Most-missed topic: identify the question/topic with the highest number of incorrect answers.

Reporting behavior: compare correct reporting before and after awareness training during authorized exercises.

3. Remediation / Hardening Recommendations

- Enable multi-factor authentication (MFA).
- Strengthen email filtering and anti-phishing controls.
- Verify payment, password-reset and sensitive-information requests through trusted channels.
- Provide a clear IT/security reporting route.
- Run recurring phishing-awareness training.
- Apply least privilege to reduce the impact of compromised accounts.
- Monitor reports and investigate recurring phishing patterns.
- Keep operating systems, browsers and security software updated.

4. Training Response Model

STOP: Do not click, reply or open unexpected attachments.

CHECK: Inspect sender details, wording, links and requests.

VERIFY: Confirm through an independently trusted channel.

REPORT: Send the suspicious message to the organization's IT/security team according to policy.

5. Expected Outcome

The expected outcome is improved user recognition of phishing indicators, safer verification behavior and increased reporting of suspicious messages. Metrics should be reviewed after training to identify areas requiring additional education.

6. Safety and Privacy

Metrics should avoid collecting unnecessary personal or sensitive information. The project should not collect passwords, OTPs, banking information or other secrets. Any real-world awareness exercise must be authorized and governed by organizational policy.